

Final project: Incident response report template

Use this template to structure your final incident response report. Complete each section with relevant findings, supporting evidence, and clear, actionable recommendations. For additional guidance, refer to [Reading: What to Include in an Incident Response Report](#).

1. Executive summary (3 points)

Provide a plain-language summary for non-technical readers. Briefly explain what happened, how it was discovered, the scale of the impact, and the current remediation status.

Your response:

A basic vulnerability assessment was conducted using OpenVAS against a deliberately vulnerable virtual machine (Metasploitable2). The scan revealed multiple critical and high-severity vulnerabilities, including outdated services and default credentials. This simulated environment enabled hands-on experience in identifying and understanding exploitable system weaknesses. Remediation steps and recommendations are provided to mitigate real-world risks.

2. Incident timeline (3 points)

Present a chronological sequence of key events, using real or simulated timestamps. Include detection, investigation, containment, remediation, and lessons learned. Use a table or bullet list.

Your response:

Time	Event Description	
10:00 AM	Metasploitable2 VM booted and network IP identified	
10:15 AM	OpenVAS services initialized on Kali Linux	
10:20 AM	Target configured in OpenVAS with default scan settings	
10:25 AM	Scan launched (Full and Fast profile)	
11:45 AM	Scan completed; report reviewed	
12:00 PM	Top vulnerabilities analyzed; mitigation strategies noted	

3. Systems affected (3 points)

List each impacted asset: hostnames, IP addresses, exposed services, user accounts, and system roles (e.g., DMZ web server).

Your response:

Hostname: Metasploitable2
IP Address: 192.168.56.101 (example)
Services: FTP (port 21), SSH (port 22), Telnet (port 23), Apache (port 80)
User Accounts: msfadmin
System Role: Test VM (vulnerable simulation environment)

4. Root cause analysis (3 points)

Explain the underlying vulnerability or weakness that allowed the incident. Reference CVEs, scan data, and log evidence. Indicate if the issue was technical, procedural, or both.

Your response:

The scan revealed default configurations, outdated software, and services with known CVEs:

- **CVE-2017-5638:** Apache Struts RCE
 - **CVE-2010-0738:** Tomcat JMX Remote exploit
 - **CVE-2007-2447:** Samba "username map script" command execution
- Root causes include poor patch management and use of default credentials, which are both technical and procedural failures.

5. Indicators of compromise (IoCs) (3 points)

Provide technical artifacts linked to the attack, such as IP addresses, file hashes, registry entries, rogue processes, or suspicious commands. Use validated sources where possible.

Your response:

- **Open Ports:** 21, 22, 23, 80, 445
- **Default credentials:** msfadmin:msfadmin
- **Vulnerable Software Versions:** Apache 2.2.8, Samba 3.0.20, VSFTPD 2.3.4

6. Threat intelligence integration (3 points)

Correlate the observed activity with known threat actor tactics, techniques, and procedures (TTPs) using frameworks like MITRE ATT&CK. Reference campaigns or advisories from trusted sources if relevant.

Your response:

The vulnerabilities align with common exploitation tactics in the **MITRE ATT&CK framework**:

- **T1190**: Exploit Public-Facing Application
 - **T1078**: Valid Accounts (default credentials)
 - **T1210**: Exploitation of Remote Services
- Referenced in public exploits like **Exploit-DB** and advisories from **CISA**.

7. Containment actions (3 points)

Describe specific actions taken to stop the threat: isolating hosts, killing processes, disabling services, revoking credentials, or blocking IPs. List these in the order they occurred.

Your response:

- VM was isolated from public network (host-only mode)
- Services not restarted during scan
- Scan logs and system snapshots preserved for analysis

8. Remediation steps (3 points)

Detail what was done to clean and restore systems—patches, configuration changes, re-imaging, restarting services. Include before-and-after scan results or screenshots if available.

Your response:

- Recommended disabling unused services (Telnet, FTP)
- Upgrade or patch vulnerable software (Apache, Samba)
- Enforce non-default credentials for all user accounts
- Apply host-based firewall rules to restrict exposure

9. Lessons Learned (2 points)

Reflect on security or operational gaps exposed by the incident—such as patch management delays, missing logs, or social engineering success. Note improvements needed.

Your response:

The lab emphasized how default configurations and unpatched software present major risks. It also highlighted the importance of regularly scheduled vulnerability scans and system hardening.

10. Recommendations (2 points)

Provide clear, actionable, and measurable steps to reduce future risk. Include both tactical (e.g., “Apply all critical patches within 72 hours”) and strategic (e.g., “Implement quarterly credentialed scans”) recommendations.

Your response:

- **Tactical:** Apply all critical patches within 48 hours of disclosure
- **Strategic:** Implement monthly unauthenticated vulnerability scans and bi-annual credentialed scans
-  Enforce a policy against using default passwords in any environment

11. Appendices (2 points)

Attach supporting evidence: OpenVAS scan reports, screenshots, CVE references, log files, command output, or annotated images that support your findings.

Your response:

- OpenVAS Scan Report (exported HTML/PDF)